Security & Privacy Disclosure, Final Report

Pegasus Airlines Android (com.pozitron.pegasus)

EU card payments flow through three Turkish payment vendors with no Art. 46 safeguard on record and no consent platform in the app, eleven messages over 65 days drew no reply of any kind, and none of the three questions on record was ever answered

PUBLIC DISCLOSURE, 17 OCTOBER 2026 - EMBARGO REACHED 27 SEPTEMBER 2026, ELEVEN MESSAGES SENT, ZERO REPLIES, THREE QUESTIONS NEVER ANSWERED

Target	Pegasus Hava Tasimaciligi A.S., Istanbul, Turkey (Pegasus Airlines). App developed by Pozitron, Istanbul. Contacts privacy@flypgs.com, security@flypgs.com, press@flypgs.com
Package	com.pozitron.pegasus v3.71.1
Platform Audited	Android, root level code analysis of the Google Play production build
Initial Disclosure (R1)	2026-06-27, to privacy@flypgs.com, security@flypgs.com and press@flypgs.com, BCC BfDI, KVKK and CERT.at
Disclosure / Embargo Date	2026-09-27
Report Published	2026-10-17
Overall Severity	HIGH
Findings	3 (1 High, 2 Medium, 0 Critical)
Correspondence	11 messages sent by RFI-IRFOS over 65 days (2026-06-27 to 2026-08-31). 0 replies of any kind, 0 automated acknowledgments, 0 bounces, 0 of 3 questions answered
Authorities Notified	Austrian Datenschutzbehoerde (dsb@dsb.gv.at) and European Data Protection Supervisor (edps@edps.europa.eu), BCC from 2026-06-30 and visible CC from 2026-07-23 and 2026-08-04 · Bundesbeauftragter fuer den Datenschutz (BfDI), KVKK and CERT.at, BCC on the initial disclosure

security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Operator Context 4

3 Engagement Summary 5

4 Findings 5
- 4.1 H1: EU payment card data processed through three Turkish vendors with no documented Art. 46 safeguard . . . 5
- 4.2 M1: No consent management platform, Firebase initialises before any consent decision . . . 6
- 4.3 M2: Dynatrace APM with a dedicated pinned pipeline, processor not named . 6

5 Impact Analysis 7

6 The Complete Chain: Eleven Messages, 65 Days, Zero Replies 7

7 Data Protection – Article by Article 7

8 Regulatory & Legal Landscape 8

9 Indicators of Compromise 8

10 Disclosure Timeline & Outcome 8

11 Residual Risk & Recommendations 9

Executive Summary

The Pegasus Airlines Android app processes the payment card data of EU users through three Turkish technology vendors: Monitise MEA (2,302 classes), BKM, the Turkish interbank card centre (83 classes), and Cardtek Masterpass (106 classes). Turkey has no EU adequacy decision, and no Art. 46 GDPR transfer safeguard is documented at the app layer. The app also ships no consent management platform, and Firebase initialises at process start before any consent decision can exist.

Root level code analysis of production build v3.71.1 produced one HIGH and two MEDIUM findings and no CRITICAL finding. The original disclosure labeled the first two findings CRITICAL. This report applies CVSS v4.0 and reclassifies them as stated in each finding.

The app also does a number of things well: Cardinal Commerce provides 3D Secure authentication, USE_BIOMETRIC serves login only, and the app declares no background location access.

RFI-IRFOS sent the disclosure on 27 June 2026 and ten follow-ups through 31 August 2026. No reply of any kind arrived from any of the three addressed mailboxes. The embargo of 27 September 2026 passed unanswered. This report publishes 20 days after the embargo with the full record intact.

ID	Severity	Title
H1	HIGH	EU payment card data processed through three Turkish vendors with no documented Art. 46 safeguard
M1	MEDIUM	No consent management platform, Firebase initialises before any consent decision
M2	MEDIUM	Dynatrace APM with a dedicated pinned pipeline, processor not named

Subject & Operator Context

The app com.pozitron.pegasus is the mobile booking and check-in client of Pegasus Airlines, operated by Pegasus Hava Tasimaciligi A.S. in Istanbul and developed by Pozitron, also in Istanbul. EU travellers use the app to book flights and pay by card. The disclosure went to privacy@flypgs.com, security@flypgs.com and press@flypgs.com, the three public contact mailboxes of the operator.

Engagement Summary

RFI-IRFOS sent the initial disclosure on 27 June 2026 to the three Pegasus mailboxes, with the BfDI, KVKK and CERT.at in BCC, stating an embargo date of 27 September 2026. The letter led with what the team got right, then presented the findings and asked three questions: under which Art. 46 mechanism EU payment card data is transferred to BKM, Cardtek and Monitise MEA and since when; whether the internal data protection officer has been informed and when; and whether an Art. 35 data protection impact assessment covers the payment flows and when it was completed.

Ten follow-ups were sent (30 June twice, 6 July, 17 July, 23 July, 27 July, 4 August, 15 August, 24 August and 31 August 2026). The Austrian Datenschutzbehoerde and the EDPS were in BCC from 30 June and in visible CC from 23 July and 4 August respectively. No reply of any kind arrived in the thread and no message bounced.

Findings

H1: EU payment card data processed through three Turkish vendors with no documented Art. 46 safeguard

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N, 8.7 - card data path through BKM, Cardtek and Monitise MEA, no transfer mechanism on record

```
Monitise MEA          2302 classes   digital banking / mobile payment platform   TR /
    UAE
BKM                     83 classes   Turkish interbank card centre (national card
    scheme)   TR
Cardtek Masterpass     106 classes   card tokenisation + NFC   TR

Firebase project_id: flypgs-95c47
google_api_key: …AIzaSyXXXXXX (withheld, disclosed privately in the R1 letter)
```

Impact: The production build ships Monitise MEA (2,302 classes, digital banking and mobile payment platform, Turkey and UAE), BKM Bankalararasi Kart Merkezi (83 classes, the Turkish national card scheme) and Cardtek Masterpass (106 classes, card tokenisation and NFC). Payment card data (card number, cardholder name, expiry date, CVV) is personal data under Art. 4(1) GDPR. Art. 44 prohibits a transfer to a third country unless an adequacy decision under Art. 45 or appropriate safeguards under Art. 46 exist. Turkey has no adequacy decision, and the app layer shows no SCC, BCR or other mechanism and no Art. 13(1)(f) transfer notice. The operator can answer this from its contracts, and it is the first of the three questions on record. The R1 letter labeled this finding CRITICAL. This report classifies it HIGH under CVSS v4.0 because the finding rests on the shipped SDK stack and the missing documentation, and RFI-IRFOS did not exercise a live payment transaction.

M1: No consent management platform, Firebase initialises before any consent decision

MEDIUM, CVSS v4.0 AV:N/AC:H/AT:N/PR:N/UI:R/VC:L/VI:N/VA:N/SC:L/SI:N/SA:N, 4.8 - process-start analytics and crash telemetry without a consent gate

```
FirebaseInitProvider   initOrder=100   directBootAware=true
RECEIVE_BOOT_COMPLETED receiver
Consent management platform (OneTrust / Didomi / Usercentrics / IABTCF): none
```

Impact: The app ships no consent management platform. FirebaseInitProvider (initOrder=100, directBootAware=true) starts at process start, and a RECEIVE_BOOT_COMPLETED receiver fires at device boot, so no consent signal can exist before Firebase initialises. Firebase Analytics and Crashlytics collect device identifiers, session data and crash telemetry, and the app documents no legal basis for this processing for EU users. The R1 letter labeled this finding CRITICAL. This report classifies it MEDIUM under CVSS v4.0 because the collected data is device and session telemetry and RFI-IRFOS did not measure the transmitted payloads.

M2: Dynatrace APM with a dedicated pinned pipeline, processor not named

MEDIUM, CVSS v4.0 AV:N/AC:H/AT:N/PR:N/UI:R/VC:L/VI:N/VA:N/SC:L/SI:N/SA:N, 4.8 - Dynatrace real user monitoring pipeline to pegasusum.com

```
Dynatrace APM       592 classes
pinned certificate  pegasusum.com (custom)
```

Impact: Dynatrace APM (592 classes) is configured with a custom certificate pinned for pegasusum.com in the network security config. Dynatrace Real User Monitoring captures network request metadata, response content and user interaction events, and the dedicated pipeline carries EU user session telemetry to Dynatrace infrastructure. Dynatrace is not named as a data processor in the privacy information, which Art. 13(1)(e) and Art. 28 require for recipients and processors. The R1 letter labeled this finding HIGH. This report classifies it MEDIUM under CVSS v4.0 because the finding concerns telemetry and a missing processor disclosure.

Impact Analysis

The findings are fixable documentation and architecture gaps, and the app has genuine strengths. What sets this case apart is the correspondence: eleven messages over 65 days to three operator mailboxes, with no reply, no acknowledgment and no bounce. A traveller who pays by card in this app has no way to learn from the operator which legal mechanism covers the transfer of that card data to Turkish payment vendors, or whether the data protection officer knows.

The Complete Chain: Eleven Messages, 65 Days, Zero Replies

Step 1 – Disclosure sent: RFI-IRFOS sends the full findings on 27 June 2026 to privacy@flypgs.com, security@flypgs.com and press@flypgs.com, with the BfDI, KVKK and CERT.at in BCC, stating an embargo of 27 September 2026.

Step 2 – Silence: follow-ups on 30 June (twice), 6 July, 17 July, 23 July and 27 July 2026 restate the findings and the three questions. No reply of any kind.

Step 3 – Silence continues, regulators in visible CC: follow-ups on 4 August, 15 August, 24 August and 31 August 2026 carry the Austrian Datenschutzbehoerde and the EDPS in CC. No reply.

Step 4 – Embargo passes unanswered: 27 September 2026 passes with no reply and no delivery failure on record.

Step 5 – Publication: this report publishes 20 days after the embargo with all three questions unanswered and the card data path unchanged in the record.

Data Protection – Article by Article

Art. 44-46 GDPR – Third-country transfers: H1's flow of EU payment card data to BKM, Cardtek and Monitise MEA in Turkey requires an adequacy decision or a documented safeguard, and Turkey has no adequacy decision.

Art. 13(1)(f) GDPR – Transparency: the transfer and its safeguard must be named in the privacy information.

Art. 6 and Art. 7 GDPR – Lawfulness and consent: M1's process-start Firebase initialisation runs without a consent platform.

Art. 13(1)(e) and Art. 28 GDPR – Recipients and processors: M2's Dynatrace pipeline requires Dynatrace to be named and bound by a processor agreement.

Regulatory & Legal Landscape

Pegasus Airlines is established in Turkey and offers services to EU residents, so the GDPR applies under Art. 3(2). The BfDI was in BCC on the initial disclosure as a directly affected EU supervisory authority, as were the Turkish KVKK and CERT.at. The Austrian Datenschutzbehoerde and the EDPS were in BCC from 30 June 2026 and in visible CC from 23 July and 4 August 2026.

Fine exposure under GDPR: Art. 83(4) applies to the Art. 28 issue in M2, up to EUR 10,000,000 or 2% of total worldwide annual turnover. Art. 83(5) applies to the Art. 44-46, Art. 13, Art. 6 and Art. 7 issues in H1 and M1, up to EUR 20,000,000 or 4% of total worldwide annual turnover.

Indicators of Compromise

The following items were extracted from the published production APK via root level code analysis only. No Pegasus servers, accounts or infrastructure were probed. The Google API key is withheld from this public report; the full value was disclosed privately to Pegasus in the original R1 letter.

```
H1 -- Monitise MEA (2302 classes), BKM (83), Cardtek Masterpass (106)
M1 -- FirebaseInitProvider initOrder=100 directBootAware=true, RECEIVE_BOOT_COMPLETED,
     no CMP
M2 -- Dynatrace APM (592 classes), pinned certificate pegasusum.com
Firebase project_id flypgs-95c47, google_api_key …AIzaSyXXXXXX (redacted)
```

Disclosure Timeline & Outcome

2026-06-27 Initial disclosure sent to privacy@flypgs.com, security@flypgs.com and press@flypgs.com, BCC BfDI, KVKK and CERT.at. Embargo stated as 2026-09-27.

2026-06-30 Two follow-ups sent, Austrian Datenschutzbehoerde and EDPS in BCC. No reply.

2026-07-06 Follow-up sent. No reply.

2026-07-17 Follow-up sent. No reply.

2026-07-23 Follow-up sent, Austrian Datenschutzbehoerde in visible CC. No reply.

2026-07-27 Follow-up sent. No reply.

2026-08-04 Follow-up sent, Austrian Datenschutzbehoerde and EDPS in visible CC. No reply.

2026-08-15 Follow-up sent, both regulators in visible CC. No reply.

2026-08-24 Follow-up sent, both regulators in visible CC. No reply.

2026-08-31 Follow-up sent, both regulators in visible CC. No reply.

2026-09-27 Embargo date reached and passed with all three questions unanswered.

2026-10-17 This report published, 20 days after the embargo date. Correspondence record: eleven RFI-IRFOS messages, zero replies, zero automated acknowledgments, zero bounces, zero of three questions answered.

Residual Risk & Recommendations

H1 – Name the Art. 46 mechanism for each of BKM, Cardtek and Monitise MEA, document the date it took effect, and state the safeguard in the privacy information under Art. 13(1)(f).

M1 – Defer Firebase initialisation until a consent decision is recorded, and introduce a consent management platform for EU users.

M2 – Name Dynatrace as a processor in the privacy information and document the Art. 28 agreement.

Procedural: RFI-IRFOS remains open to a substantive human reply to the three questions at any time; this report will be updated to reflect one if it arrives.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from root level code analysis of the published application using publicly available tooling. No Pegasus servers, accounts, or infrastructure were probed. Credential values are withheld from this public report and were disclosed privately to Pegasus in the original R1 letter. Analysis by RFI-IRFOS, ZVR 1015608684, GISA 39261441, Steuernummer 68 696/8736. REF PEGASUS-2026-R1-001.